



يونيڤرسيتي سلطان زين العابدين
Unisza
UNIVERSITI SULTAN ZAINAL ABIDIN

GROUP PROJECT

SEMESTER : 6

SESSION : 2025/2026

CLASS : KRK6

CODE : CSA34203

COURSE : COMPUTER FORENSICS

LECTURER : SIR AHMAD FAISAL AMRI BIN ABIDIN @ BHARUN

**TITLE : COMPREHENSIVE DIGITAL FORENSICS INVESTIGATION
AND EXPERT TESTIMONY SIMULATION**

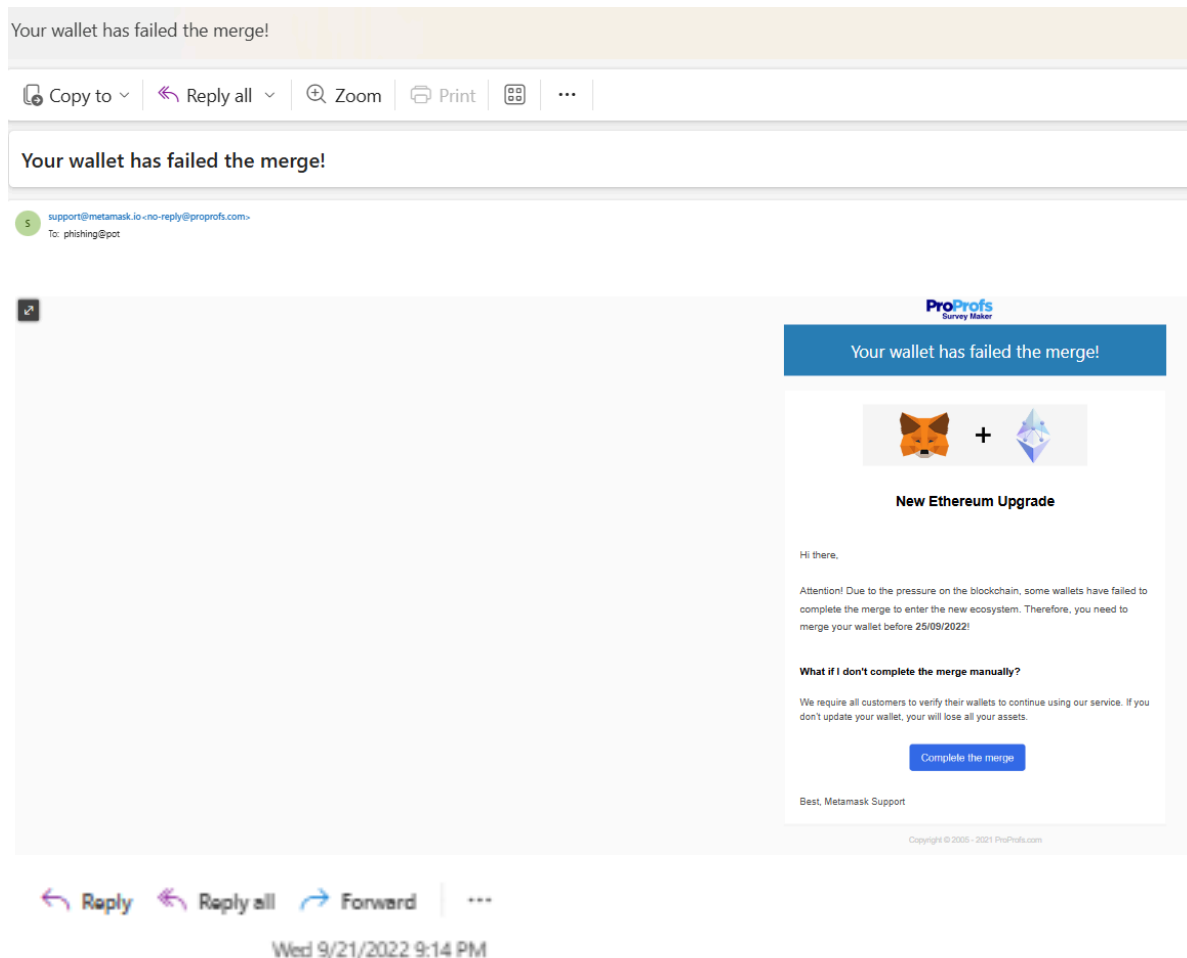
NAME	NO MATRIX
ELYANA INSYIRAH BINTI MOHD SUHAIMI	076976

PART E — Email Forensics (10 marks)

E.1 Phishing Email Analysis

A sample phishing email (phishing.eml) was examined to trace the true sender, identify spoofed headers and detect malicious intent.

Below is what appears to be an email from MetaMask, which is one of the world's most popular digital wallets for cryptocurrency.



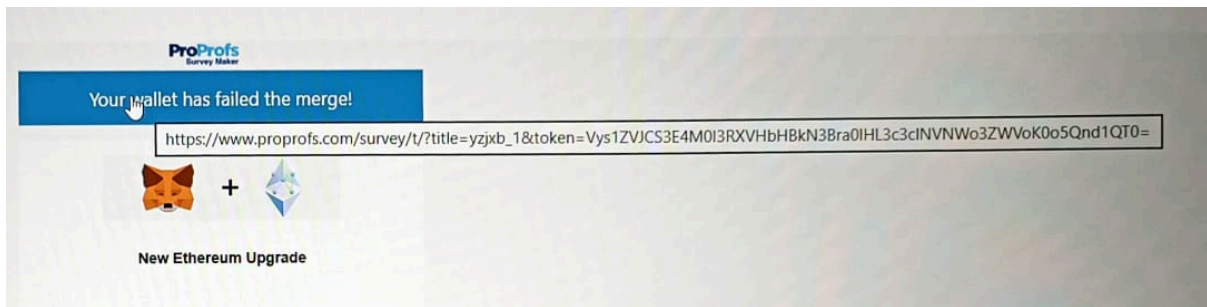
Source: https://github.com/rf-peixoto/phishing_pot/blob/main/email/sample-1.eml

Sample: sample-65.eml

From reading and observing the email as it is, we can identify a few flags that prove the email is a phishing email.

Observation 1: Suspicious Sender

The sender of the email appears as “support@metamask.io <no-reply@proprofs.com>”. This shows that they spoofed the Display Name part of the header to read support@metamask.io which contradicts the actual email address it was sent from (no-reply@proprofs.com). Additionally, ProProfs Survey Maker’s logo is also clearly shown at the top of the email, indicating that the attacker used it to generate the survey. The Copyright at the bottom email also shows Copyright © 2005 - 2021 ProProfs.com, instead of Metamask’s. Another proof would be when the cursor hovers at the top of the survey, ProProfs link appears.

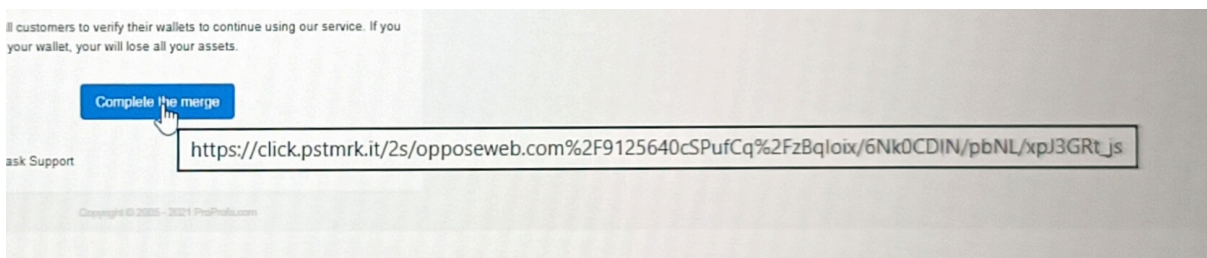


For context, ProProfs Survey Maker is a cloud-based SaaS platform designed to create, distribute and analyze online surveys, polls and forms. Because ProProfs is a legitimate service, anyone can go to their website and create a free account to build a survey. Scammers often seem to abuse this feature. This is an alarming sign since legitimate companies will never send official account warnings through a third-party survey company's email address.

Observation 2: Urging and Threatening User

The email was received on Wed 21st September 2022 at 9:14PM and the attacker demanded payment before 25th September 2022 while threatening the user for asset loss if any failure to do so. This is a common tactic observed in phishing emails where they perform social engineering by giving users a sense of urgency, short due dates and threats to scare them to do as they say.

Observation 3: Suspicious Link



Although the link starts with https://, it does not mean the link or the page it directs to is safe. The breakdown of the link is as below:

1. https:// means connection to the first server that gets a hit is secure. However, this hardly indicates that the destination is safe.

2. click.pstmrk.it is the main domain of this link and it belongs to Postmark, a legitimate email delivery service. Scammers often sign up for free trials or compromise legitimate accounts on services like Postmark. By using Postmark's or any other legitimate email service tracking link, the email is much more likely to bypass email provider's spam filters.
3. opposeweb.com which appears in the middle of the link (opposeweb.com%2F9125640cSPufCq%2FzBqloix) is a hidden redirect: The %2F is computer code (URL encoding) for a forward slash (/). This reveals the true destination. If the link is clicked on:
 - A user will securely connect to Postmark's server.
 - Postmark registers that user clicked the link.
 - Postmark instantly redirects the user to the hidden destination: opposeweb.com/9125640cSPufCq/zBqloix.

This indicates that the sender hides behind a trusted email tracking service to bypass email security and redirect users to another website, which is a common tactic used by scammers for phishing attempts and even malware delivery.

E.2 Header Trace — SMTP Flow

Email headers are read bottom-to-top (oldest hop first). The 'Received' fields trace the path from the sender's server to recipient.

Email Header:

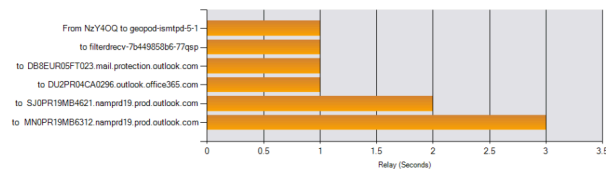
```
Received: from SJ0PR19MB4621.namprd19.prod.outlook.com (::1) by
MN0PR19MB6312.namprd19.prod.outlook.com with HTTPS; Wed, 21 Sep 2022 21:14:06
+0000 Received: from DU2PR04CA0296.eurprd04.prod.outlook.com (2603:10a6:10:28c::31)
by SJ0PR19MB4621.namprd19.prod.outlook.com (2603:10b6:a03:28a::19) with Microsoft
SMTP Server (version=TLS1_2,
cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.5654.17; Wed, 21
Sep 2022 21:14:04 +0000 Received: from
DB8EUR05FT023.eop-eur05.prod.protection.outlook.com (2603:10a6:10:28c:cafe::7) by
DU2PR04CA0296.outlook.office365.com (2603:10a6:10:28c::31) with Microsoft SMTP
Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id
15.20.5654.16 via Frontend Transport; Wed, 21 Sep 2022 21:14:03 +0000
Authentication-Results: spf=pass (sender IP is 168.245.101.190)
smtp.mailfrom=email.proprofs.com; dkim=pass (signature was verified)
header.d=proprofs.com;dmarc=bestguesspass action=none
header.from=proprofs.com;compauth=pass reason=109 Received-SPF: Pass
(protection.outlook.com: domain of email.proprofs.com designates 168.245.101.190 as
permitted sender) receiver=protection.outlook.com; client-ip=168.245.101.190;
helo=o168-245-101-190.outbound-mail.sendgrid.net; pr=C Received: from
o168-245-101-190.outbound-mail.sendgrid.net (168.245.101.190) by
DB8EUR05FT023.mail.protection.outlook.com (10.233.239.43) with Microsoft SMTP Server
```

(version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id
15.20.5654.14 via Frontend Transport; Wed, 21 Sep 2022 21:14:03 +0000
X-IncomingTopHeaderMarker:
OriginalChecksum:E889720F7EC977CCE01B1CD831B9FF0C91AC5CE55DF8F26DCF7F5
BA93DA127F4;UpperCasedChecksum:8AFF2BEC35D26EDBE099CC58EDE0FE8CE9C3F
22CCF240E257F6C8B3871E46371;SizeAsReceived:1792;Count:15 DKIM-Signature: v=1;
a=rsa-sha256; c=relaxed/relaxed; d=proprofs.com;
h=content-transfer-encoding:content-type:from:mime-version:subject: reply-to:to:cc;
s=smtapi; bh=oD4BIWEM5DuueQbfSVJC7Un8JFr/nZrbkm4kp6XMgzA=;
b=kbieRZ3BvXoNBoem/eqWxNIuzQXXS/kKUoUbc7Dd55blszDOF2kqNNTAIVIBJm7RdYm5
0A88i4EukCwhZhQadyrHT4INRcB1ZR5QcMWxe9+g7u6Vajd3RQf0zPOXlrlhf0Ld1vJn7Y
KxgSgRP6S5SPCsLI/CpE/U8nZxTUMsyLI= Received: by
filterdrecv-7b449858b6-77qsp with SMTP id filterdrecv-7b449858b6-77qsp-1-632B7E9A-3E
2022-09-21 21:14:02.235624227 +0000 UTC m=+169265.422124849 Received: from
NzY4OQ (unknown) by geopod-ismtpd-5-1 (SG) with HTTP id
eVnK4bVzQ2qQi4KK8ifhiA Wed, 21 Sep 2022 21:14:02.179 +0000 (UTC)
Content-Transfer-Encoding: quoted-printable Content-Type: text/html; charset=iso-8859-1
Date: Wed, 21 Sep 2022 21:14:02 +0000 (UTC) From: "support@metamask.io"
<no-reply@proprofs.com> Message-ID:
<eVnK4bVzQ2qQi4KK8ifhiA@geopod-ismtpd-5-1> Subject: Your wallet has failed the
merge! Reply-To: support@metamask.io X-SG-EID:
=?us-ascii?Q?zcOY4w2Lb9ITyFBqnmPC2Zysf5JvVhZ2W+b53rp9XUQiTMFxfjV5A1UDZQ8d
L8l?=?us-ascii?Q?MzE2g1FYBlwTg0Zm=2Fv9vqtlKIN3=2Fwx1VORj8Etn?=
=?us-ascii?Q?QFBel+8jtHO9SzUcLBKW2eLSq6gYVult9dylwVg?=
=?us-ascii?Q?IOEEsOvB1MslpplhJa9ViAHmF7ujEbpXe5NLhM?=
=?us-ascii?Q?n5avewXI+w+AqU4ZNdvQN=2FCSSP71mkiZIBAiFER?=
=?us-ascii?Q?DnfE5sw098kVGmrzIG5K63krWKsmLlyTB5EuaHz?=
=?us-ascii?Q?5ergKizevdE6lYtszEB4Q=3D=3D?=? X-SG-ID:
=?us-ascii?Q?N2C25iY2uzGMFz6rgvQsbwWxZLDPzqBLXZiXxuFWfKBxLGr8BxK7KyNXtK
Kkip?=?us-ascii?Q?3c7INYf9rLO=2F3C1vpjcCXOtIN0pj+FE4zd7STmo?=
=?us-ascii?Q?tKyigiBGg995qKkr497RGd2Pk89TrYJb5eGbYW?=
=?us-ascii?Q?SzS9qVb5aw=3D=3D?=? To: phishing@pot X-Entity-ID:
nJqfvQ3eGVSRs3fDZMPvHg== X-IncomingHeaderCount: 15 Return-Path:
bounces+7689-3170-phishing@pot@hotmail.com@email.proprofs.com
X-MS-Exchange-Organization-ExpirationStartTime: 21 Sep 2022 21:14:03.7918 (UTC)
X-MS-Exchange-Organization-ExpirationStartTimeReason: OriginalSubmit
X-MS-Exchange-Organization-ExpirationInterval: 1:00:00:00.0000000
X-MS-Exchange-Organization-ExpirationIntervalReason: OriginalSubmit
X-MS-Exchange-Organization-Network-Message-Id:
1c619dc5-c08b-40db-7461-08da9c163624 X-EOPAttributedMessage: 0
X-EOPTenantAttributedMessage: 84df9e7f-e9f6-40af-b435-aaaaaaaaaaaaa:0
X-MS-Exchange-Organization-MessageDirectionality: Incoming X-MS-PublicTrafficType:
Email X-MS-TrafficTypeDiagnostic: DB8EUR05FT023:EE_|SJ0PR19MB4621:EE_
X-MS-Exchange-Organization-AuthSource:
DB8EUR05FT023.eop-eur05.prod.protection.outlook.com
X-MS-Exchange-Organization-AuthAs: Anonymous X-MS-UserLastLogonTime: 9/21/2022
9:00:21 PM X-MS-Office365-Filtering-Correlation-Id:

1c619dc5-c08b-40db-7461-08da9c163624 X-MS-Exchange-EOPDirect: true X-Sender-IP: 168.245.101.190 X-SID-PRA: NO-REPLY@PROPROFS.COM X-SID-Result: PASS X-MS-Exchange-Organization-PCL: 2 X-MS-Exchange-Organization-SCL: 2 X-Microsoft-Antispam: BCL:4; X-MS-Exchange-CrossTenant-OriginalArrivalTime: 21 Sep 2022 21:14:03.3700 (UTC) X-MS-Exchange-CrossTenant-Network-Message-Id: 1c619dc5-c08b-40db-7461-08da9c163624 X-MS-Exchange-CrossTenant-Id: 84df9e7f-e9f6-40af-b435-aaaaaaaaaaaa X-MS-Exchange-CrossTenant-AuthSource: DB8EUR05FT023.eop-eur05.prod.protection.outlook.com X-MS-Exchange-CrossTenant-AuthAs: Anonymous X-MS-Exchange-CrossTenant-FromEntityHeader: Internet X-MS-Exchange-CrossTenant-RMS-PersistedConsumerOrg: 00000000-0000-0000-0000-000000000000 X-MS-Exchange-Transport-CrossTenantHeadersStamped: SJ0PR19MB4621 X-MS-Exchange-Transport-EndToEndLatency: 00:00:02.9240124 X-MS-Exchange-Processed-By-BccFoldering: 15.20.5632.019 X-Microsoft-Antispam-Mailbox-Delivery: abwl:0;wl:0;pcwl:0;kl:0;iwl:0;ijl:0;awl:0;dkl:0;rw:0;ucf:0;jmr:0;ex:0;auth:1;dest:1;ENG:(506200 0305)(90000117)(90005022)(91005020)(91035115)(5061607266)(5061608174)(9050020)(9 100338)(4810004)(4910033)(8810097)(9910022)(9545005)(10170022)(9320005); X-Message-Info: qZelhiYnPmqyTh83iWcTVJowa4B52gl/JLsKz8DeLTCQyW3Ans2bMZge14di9NqeM4ad4tF O+51gck3aHVI3dhs5eQiQmd4GITqVms6t5eXv9yUKEiBpgRQbWnHSctvOwlU0KsMZL89I8t Ctenn7PUM2i8cbp1uLGwOZN0/HkUGhKqOTqxFcpPyEB+cu0/ZS2IVUYAaz9qrrP1X85Bww == X-Message-Delivery: Vj0xLjE7dXM9MDtsPTA7YT0wO0Q9MTtHRD0yO1NDTD0tMQ== X-Microsoft-Antispam-Message-Info: =?iso-8859-1?Q?d5o8Rh+T0ZmgiwnYBtJ2z1bw11jY09RsaKOimAdeNuK0gCXmk6xh62hzr q?= =?iso-8859-1?Q?pLW2ITSwfAJzii+mFTc92UZM3hIGWwtAm1EZ+442ZLrZ1prBiqyc2NrOk? = =?iso-8859-1?Q?406hVG+2AWMAilGizgPfd6drNTQInam1Ar86JzKYQwyTei/KZ77GNA8z8j? = =?iso-8859-1?Q?aUv4zVDQM/KUtnjeBs/DY8ufhnGildoksK2j2xDZQKax4fNxazhEjxwhM8?= =?iso-8859-1?Q?1TNwC6M1genVgNi6/qQIQuwLq99SksNDH1cU2SOVE+Jp3wcxQT1q9Wd z8W?= =?iso-8859-1?Q?PSRJ1xOvdviiPIYAWAyysGSiliugo3rrXFhS4H1oxsVUhZCSPACU8xbyDX? = =?iso-8859-1?Q?rvclxgdjlqaS9jMPZflccF0ILVS1R40fGVXJvBc0dX2XkYPFL3Ci5bT7k?= =?iso-8859-1?Q?AmhNQ809cP76/xtxWM9IPByg+8sZTFdgPacZ/RUFRBCOEiQyqiuNTDTR v5?= =?iso-8859-1?Q?jdNnjiov4xVnRcsdLwTOcX3qOXzSbgohru8mTDJdvp+36R3AmlWsG8SQb l?= =?iso-8859-1?Q?HPBmFYtB5BS+1vNWYbj8Dq+/8Alxzzoqx6lGp3dGtqXt2il9bcJABqAWr?= =?iso-8859-1?Q?uCnALKfvVemL+S/JeX0j04IDFOBLQ6hLjGo2i3VpgWPBfX8e53cKIYFCOr? = =?iso-8859-1?Q?opobQf+3M5e5Axd7mmgucYG8947dUCKC9cgwZMvc1x9vZ/SWXiziMDct BN?= =?iso-8859-1?Q?pNgmdMw39AFYjce7Q5jMzLk6XZJo9oyCz+e+PMgvco6BawOnX0295IP9 ma?= =?iso-8859-1?Q?4b/bla1Yw+a9BbDUQxlyL/sRPlq3s3JAscW1nCUvQopZeJoGAnHoK9y/C+

?=
=?iso-8859-1?Q?iJgtNxo2AlkrytYn8pN5Uu9SoMtv19GGTQyAR2OIk7Fgo1P1zIl1xiD0jU?=
=?iso-8859-1?Q?EEExpbwOojveJog8xpSBJmAKrTK39AjkQiV0T7JQ1cKjHDJYr3Us7CmuA
V?=
=?iso-8859-1?Q?AHZxOwtWC9oXeVOzdtkXZb4G7iXwOzmhxgit9p4Rn1QAib3ACifKKE6Wc
a?=
=?iso-8859-1?Q?PPrumkEA+/l+xFqM257JYF3xLCPTDI+0Mvh4hvwApcbCMKuWR1Dtjs9g
Mz?=
=?iso-8859-1?Q?pFopW7kcCFqtThCKZS3Y7EGZQuLiTkECxZpzJQxsUBG9ID88liBq02ww
V4?=
=?iso-8859-1?Q?EJNbh6tbQjbR15KyFXiN1YoNiFWL2slqBOP8FqWJIKxBPsan2GD2RteiQ
1?=
=?iso-8859-1?Q?jhrZle8nWUHH65FG1uNmYKE07/8EFtfMSCUmMh9GFNIuLbUzyOGPTry
YHi?=
=?iso-8859-1?Q?ejctlVOp0CGx75c4ooaxJuLyLWb0jbyeIRFxxo6hu28s+1Y3U3aQ7w6tRJ?=
=?iso-8859-1?Q?JdB3JIMPuYnfUcy2O+ILaeL+btswC4qCicZBNNEwdlOlwvcG8Nlvg6oukX?
=
=?iso-8859-1?Q?9BXy6s4vDUQjZl2bkxEPtj1apCL26S+KATN0LcZF/JXlmlnR7wyRawlHIY?
=
=?iso-8859-1?Q?uKm+vyH2SrLaSBpw5gHXpc1EQjg2zhPYObTFTjlfQLevlbHkSUihDv8pkK
?=
=?iso-8859-1?Q?WqOhA0th33fl9Yp4parxint5uAqg3zRe7najeO1lzrczO1pR4UqoAwgtoE?=
=?iso-8859-1?Q?/p+dt5nvAWvlulduC0VmN9FwxVlOWtkFWr0M8/VVx11T3FgxmT7L8xtKp2
?=
=?iso-8859-1?Q?Z3y1r5/llfmaTtKYXAXj3uFdWDuRgxOg0U9Qz93xr6ViAf/QxSeRI37eyL?=
=?iso-8859-1?Q?sApnZK5ilXENFWnJ1iOLe+/hfdbYD5/tWcG42NQFJGu1A9Wy1ofpeNNhM
3?=
=?iso-8859-1?Q?8xAU2dDfcwLQrsrVyY+EtJteAlHwqlnMmRMZvNUeUFY++ICpr8lEx4f6j5?
=
=?iso-8859-1?Q?sT2eTgQYhVj4NVQpT3Dg6i7QxiCitQCCHiSPlwZiwtVkOh+mPP9bwdVuk
X?=
=?iso-8859-1?Q?BmpQwJg+Gkwpmcichl1jl3geWap2xT5K+KDqu5WIX68HJAzADJwUul6h
QM?=
=?iso-8859-1?Q?zMy/MrNJml9vr1tzTTIf6AI+EI5MH073OGLJ88RAsUvzzfiOf62H2/iwKE?=
=?iso-8859-1?Q?YKYeoozGEg0kOYVzLcYIMgJHEujPxPD56jepDucXahGtL6UpX6FWwzhkf
z?=?iso-8859-1?Q?kz4C3jinnoyi?= MIME-Version: 1.0

MxToolbox Header Analyser was used to analyze the header and the results are as shown and discussed below:



Hop	Delay	From	By	With	Time (UTC)	Blacklist
1	*	NzY4OQ	geopod-smtpd-5-1	HTTP		
2	*		filterdrecv-7b449858b6-77qsp	SMTP		
3	*	o168-245-101-190.outbound-mail.sendgrid.net 168.245.101.190	DB8EUR05FT023.mail.protection.outlook.com 10.23.3.239.43	Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384)	9/21/2022 9:14:03 PM	✓
4	0 seconds	DB8EUR05FT023.eop-eur05.prod.protection.outlook.com 2603.10a6:10:28c::7	DU2PR04CA0296.outlook.office365.com 2603.10a6:10:28c::31	Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384)	9/21/2022 9:14:03 PM	✓
5	1 Second	DU2PR04CA0296.eurprd04.prod.outlook.com 2603.10a6:10:28c::31	SJOPR19MB4621.namprd19.prod.outlook.com 2603.10b6:a03:28a::19	Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384)	9/21/2022 9:14:04 PM	✓
6	2 seconds	SJOPR19MB4621.namprd19.prod.outlook.com ::1	MNOPR19MB6312.namprd19.prod.outlook.com	HTTPS	9/21/2022 9:14:06 PM	✗

Table Summary

Hops 1 & 2

Represents the email being generated and prepared for transmission over the internet.

- **Hop 1 (HTTP Protocol):** Email transmission begins with HTTP request rather than an SMTP request. Indicates that it was generated through a web application or API. In this case, the attacker clicks "Send" or triggers an automated workflow within the ProProfs survey platform.
- **Hop 2 (SMTP Protocol):** The internal system (filterdrecv) receives the compiled message and prepares it for standard email delivery.
- **Analytics Note:** Both hops occurred internally within the sender's network. Since they did not touch the public internet yet, there are no timestamps or blacklist checks recorded.

Hop 3

Represents the moment the email leaves the sender's network and is evaluated by the recipient's primary security gateway.

- **The Sender:** The email is dispatched by o168-245-101-190.outbound-mail.sendgrid.net (IP Address: 168.245.101.190). SendGrid is a highly reputable enterprise email delivery service.
- **The Receiver:** It is intercepted by mail.protection.outlook.com, which is Microsoft's frontline spam and malware filter (Exchange Online Protection).
- **Security Bypass:** Because the email originated from a verified SendGrid IP address, it passed the global blacklist checks. Microsoft's automated filters deemed the sender trustworthy based on IP reputation, effectively blinding the system to the malicious payload inside.
- **Encryption:** The transmission was secured using Transport Layer Security (TLS_ECDHE_RSA_WITH_AES_256...). By abusing legitimate infrastructure, the attacker benefited from enterprise-grade encryption, making the email look even more professional and secure to automated scanners.

Hops 4 & 5

Once Microsoft accepted the email, it was routed through their internal cloud infrastructure to locate the target's specific mailbox.

- **Geographic Jumping:** The server names reveal the physical journey of the data. In Hop 4, it passes through a European data center (eop-eur05.prod.protection...). In Hop 5, it is forwarded across the Atlantic to a North American data center (namprd19.prod.outlook.com).
- **IPv6 Utilization:** IP addresses in this phase (2603:10a6...). Microsoft uses modern IPv6 routing for its internal network traffic to ensure speed and efficiency.
- **Analytics Note:** 1 second here is normal due to network latency as data travels between global data centers.

Hop 6

Actual placement of the email into the user's Exchange mailbox.

- **The Localhost Anomaly:** The sending IP is listed as ::1, which is the IPv6 loopback address for "localhost." This means the North American server (namprd19) was simply talking to itself to drop the message into the local database.
- **The False Positive:** The analyzer tool flagged this final step with a "Fail" on the blacklist check. This is an analytical error by the tool, not a security block. The tool attempted to check ::1 against public spam databases, which is impossible since it is a private internal address.
- **Delivery Protocol:** The final handoff is listed as HTTPS, indicating the mailbox was likely accessed or updated via a web protocol (like Microsoft Graph API or Outlook on the Web) at exactly 9:14:06 PM UTC.

E.3 SPF / DKIM / DMARC Authentication Results

Headers Found

Header Name	Header Value
Authentication-Results	spf=pass (sender IP is 168.245.101.190) smtp.mailfrom=email.proprofs.com, dkim=pass (signature was verified) header.d=proprofs.com,dmarc=bestguesspass action=none header.from=proprofs.com,compauth=pass reason=109
Received-SPF	Pass (protection.outlook.com: domain of email.proprofs.com designates 168.245.101.190 as permitted sender) receiver=protection.outlook.com; client-ip=168.245.101.190; helo=o168-245-101-190.outbound-mail.sendgrid.net; pr=C
X-IncomingTopHeaderMarker	OriginalChecksum:E889720F7EC977CCE01B1CD831B9FF0C91AC5CE55DF8F26DCF7F5BA93DA127F4,UpperCasedChecksum:8AFF2BEC35D26EDBE099CC58EDE0FE8CE9C3F22CCF240E257F6C8B3871E46371,SizeAsReceived:1792,Count:15
DKIM-Signature	v=1; a=rsa-sha256; c=relaxed/relaxed; d=proprofs.com; h=content-transfer-encoding:content-type:from:mime-version:subject:reply-to:to:cc;s=smtapi; bh=oD4BIWEM5DuaeQbFSVJC7Un8JFr/nZrbkm4kp6XMgzA=:b=kbleRZ3BvXoNBoem/eqWxNluzQXXS/kKJJoUbc7Dd55blszDOf2kqNNTAIVIBJm7RdYm5 0A88i4EukCwhZnQadyrHT4NRCB1ZR5QcMWxe9+g7u6Vajd3RQI0zPOXirh0Ld1vJn7Y KxgSgRP6S5SPCSL I/CpE/U8nZtUMsyLI=
Content-Transfer-Encoding	quoted-printable
Content-Type	text/html; charset=iso-8859-1
Date	Wed, 21 Sep 2022 21:14:02 +0000 (UTC)
From	"support@metamask.io" <no-reply@proprofs.com>
Message-ID	<eVnK4bVzQ2Qq4Kk8IthiA@geopod-smtpd-5-1>

Delivery Information

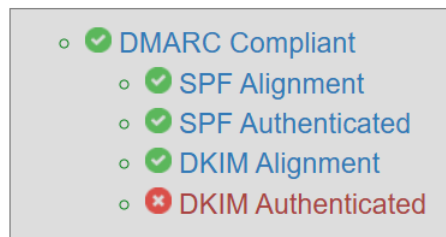


Figure and : Authentication, SPF, DKIM and DMARC results

1. SPF (Sender Policy Framework)

- **Result:** Pass
- **Why it passed:** When Microsoft received the email, it looked at the Sender (no-reply@proprofs.com) and saw if the IP address 168.245.101.190 is on the list to send emails for ProProfs.
- **The Exploit:** Because ProProfs uses SendGrid to deliver their surveys, they have officially listed SendGrid's IP addresses on their SPF list. The email genuinely came from an authorized SendGrid server, so Microsoft stamped it as a Pass.

2. DKIM (DomainKeys Identified Mail)

- **Result:** Pass (for the ProProfs domain)
- **Why it passed:** DKIM is a cryptographic wax seal. When SendGrid built the email on behalf of ProProfs, it attached an encrypted signature tied to the proprofs.com domain. When Microsoft received it, they checked the signature and confirmed the email had not been tampered with in transit..

3. DMARC (Domain-based Message Authentication, Reporting, and Conformance)

- **Result:** Pass
- **Why it passed:** DMARC checks the results of SPF and DKIM. For DMARC to pass, the domain in the hidden Envelope Sender (proprofs.com) must match the domain in the technical From address (<no-reply@proprofs.com>) and either SPF or DKIM must pass.
- **The Exploit:** Because the scammer used the legitimate no-reply@proprofs.com address for the technical routing, everything aligned perfectly. DMARC saw that SPF passed for ProProfs and that the sender address was ProProfs. Therefore, DMARC stamped it as a Pass.

If the scammer were to try to send this email from a private server and forged the technical routing to say it was from @metamask.io, SPF, DKIM and DMARC would have all failed and the email would be blocked.

E.4 Sender IP Geolocation

X-Sender-IP

168.245.101.190

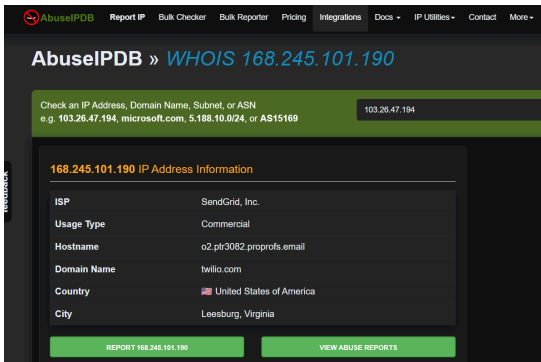


Figure and : Sender's IP and Geolocation

In the previous analysis on the Message Routing Table, the geographic path the message took from its point of dispatch to final inbox delivery was revealed. However, because the threat actor leveraged a legitimate Software-as-a-Service (SaaS) platform to generate the payload, their true physical location and originating IP address are masked and hidden.

Geographic Transit Path

The routing table traces the data through the following international path:

- Public Origin (United States):** The email was officially dispatched to the public internet from IP address 168.245.101.190. This IP block is registered to SendGrid and operates out of the United States. This represents the proxy origin of the attack, not the attacker's physical location.
- Inbound Security Gateway (Europe):** The message was first intercepted by Microsoft's Exchange Online Protection servers (designated by the eur05 tag). This indicates the email was initially routed through a European data center to undergo standard spam, malware and authentication screening.
- Final Destination (North America):** After successfully passing the European gateway checks, Microsoft's internal network forwarded the email to the recipient's specific mailbox host server (designated by the namprd19 tag), which is located in a North American data center.

Standard email phishing campaigns sent directly from a personal mail client or private server often leak the attacker's source IP in the very first "Received" header. In this incident, the attacker maintained strong Operational Security (OPSEC) by initiating the attack via an HTTP web request on the ProProfs survey platform. By building and triggering the email through a web browser, the attacker outsourced the actual sending process to ProProfs and SendGrid. As a result, the attacker's true IP address is only recorded in ProProfs' private internal web traffic logs. Based solely on the email metadata and geolocation of the threat actor is not possible.